

Durcissement Avancé Linux (Fichiers, PAM, Audit)

Objectifs

1. Sécuriser le répertoire temporaire `/tmp` contre l'exécution de charges utiles (Malwares).
2. Forcer une politique de complexité des mots de passe robuste via PAM.
3. Déployer un outil de bannissement automatique des attaques par force brute (Fail2ban).
4. Configurer la traçabilité de bas niveau (Auditd) sur un fichier système critique.

Cloisonnement du système de fichiers (Fstab)

Le répertoire `/tmp` est accessible en écriture par tous les utilisateurs. C'est le point de chute favori des attaquants pour y déposer et y exécuter des scripts de rebond ou des malwares. Nous allons interdire l'exécution dans ce répertoire au niveau du noyau.

1.1 Modification de la table de montage (Fstab)

- Ouvrez le fichier de configuration des points de montage :
`sudo nano /etc/fstab`
 - 1.
- Ajoutez la ligne suivante à la fin du fichier. (Nous utilisons `tmpfs` pour monter `/tmp` directement en mémoire vive (RAM), en y appliquant les restrictions `noexec`, `nosuid` et `nodev`) :
`tmpfs /tmp tmpfs defaults,rw,nosuid,nodev,noexec,relatime 0 0`
 - 2.
 3. Sauvegardez (`CTRL+O`, `Entrée`) et quittez (`CTRL+X`).

1.2 Application et Validation

- Forcez le système à recharger le point de montage immédiatement sans redémarrer :
`sudo mount -o remount /tmp || sudo mount -a`
 - 1.
- **Validation :** Tentez de créer et d'exécuter un script factice dans `/tmp` :
`echo 'echo "Je suis un pirate"' > /tmp/script_pirate.sh`
- `chmod +x /tmp/script_pirate.sh`
- `/tmp/script_pirate.sh`
 2. **Résultat attendu :** Le système doit bloquer l'exécution en renvoyant `Permission non`

accordée (Permission denied), même si le fichier possède les droits d'exécution (+x).

Politique de mots de passe avec PAM

Nous allons imposer des règles strictes lors de la création ou du changement des mots de passe.

2.1 Installation et configuration de PWQuality

- Installez le module PAM de vérification de qualité des mots de passe :
sudo apt-get install libpam-pwquality -y
 - 1.
- Éditez le fichier de configuration de la qualité des mots de passe :
sudo nano /etc/security/pwquality.conf
 - 2.
- Décommentez et ajustez les valeurs suivantes pour forcer au moins 14 caractères, et exiger au moins 3 types de caractères différents (majuscules, minuscules, chiffres, symboles) :
minlen = 14
- minclass = 3
 - 3.
 4. Sauvegardez et quittez.

2.2 Validation de la politique

- Tentez de changer votre propre mot de passe (ou celui d'un utilisateur de test) avec une valeur trop simple (ex: soleil) :
passwd
 1. *Résultat attendu* : Le module PAM doit rejeter le mot de passe en indiquant qu'il est trop court ou qu'il ne contient pas assez de classes de caractères.

Protection active Brute Force (Fail2ban)

Alors que le pare-feu `ufw` applique des règles statiques, `fail2ban` lit les journaux d'erreurs en temps réel et bannit dynamiquement les attaquants.

3.1 Déploiement et Configuration

- Installez le service Fail2ban :
sudo apt-get install fail2ban -y
 - 1.
- **Règle d'or** : On ne modifie jamais le fichier `jail.conf` natif car il est écrasé lors des mises à jour. Créez votre propre fichier local en le copiant :

```
sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local
```

2.

- Éditez votre nouvelle configuration locale :

```
sudo nano /etc/fail2ban/jail.local
```

3.

4. Recherchez la section `[sshd]` (vous pouvez utiliser `CTRL+W` pour chercher).

Assurez-vous que la ligne `enabled = true` est présente sous la balise `[sshd]`.

- Redémarrez le service pour appliquer :

```
sudo systemctl restart fail2ban
```

5.

3.2 Validation

- Vérifiez l'état de la "prison" SSH et le nombre d'IP bannies :

```
sudo fail2ban-client status sshd
```

1.

Traçabilité critique (Auditd)

Nous allons implémenter une surveillance de bas niveau pour alerter dès qu'un utilisateur tente de modifier la base des mots de passe locaux (`/etc/shadow`).

4.1 Mise en place de la surveillance

- Installez le démon d'audit :

```
sudo apt-get install auditd -y
```

1.

- Injectez une règle provisoire dans le noyau pour surveiller les écritures (`w`) ou les modifications d'attributs (`a`) sur le fichier `/etc/shadow`. La clé (`-k`) sert à retrouver facilement l'alerte :

```
sudo auditctl -w /etc/shadow -p wa -k ALERTE_SHADOW
```

2.

4.2 Investigation

- Simulez l'action d'un attaquant (ou d'un administrateur) en créant un nouvel utilisateur fictif, ce qui va modifier `/etc/shadow` :

```
sudo useradd compte_test
```

- Interrogez les journaux d'audit (`ausearch`) grâce à la clé définie précédemment :

```
sudo ausearch -k ALERTE_SHADOW
```

Résultat attendu : L'outil affichera l'événement d'audit précis (Syscall), incluant l'heure, la commande utilisée (`exe="/usr/sbin/useradd"`) et l'identifiant de l'utilisateur (`uid`) qui a déclenché l'action.